Checkmarx One: Questions and Answers

Oct 28, 2026 · @Please use colors that are more appealing

Plain-English answers to the questions people are most likely to ask about Checkmarx One, based on public sources reviewed in October 2026.

The basics

What is Checkmarx One?

It is a cloud platform that scans our software for security problems before the software goes live. It checks the code we write, the open-source parts we borrow, the running app and the files that set up our cloud. It then ranks what it finds so teams fix the dangerous items first.

Why do we need a tool like this?

Because attackers often get in through mistakes in software, and those mistakes cost far less to fix early. Verizon's 2025 breach report found that exploiting a software weakness started 20% of breaches. IBM puts the average data breach at $4.44 million. Veracode and Cyentia found that fixing a flaw in a company's own code typically takes about eight months.

Is this only for developers?

No. Developers see the warnings, but security staff and leadership use the dashboard to see which projects carry the most risk and whether that risk is shrinking.

What does SAST mean?

Static application security testing: reading code without running it to spot security mistakes, much like a spell-checker. The glossary at the end explains the other abbreviations.

How it compares

How does Checkmarx One compare with the alternatives?

It is the only tool in our comparison where we confirmed all six everyday security jobs: checking our code, open-source parts, the running app, cloud setup files, leaked passwords, and AI help with fixes. Forrester's 2025 report on code-scanning tools gave it the highest product score of 10 vendors, and Gartner named it a Leader for the seventh time. It trails on price clarity, and independent data on false alarms and scan speed is missing.

Who are the main competitors?

Tool	Best known for
Veracode	Cloud-only service; can check finished software without the source code
OpenText Fortify	Long-established and trusted by large, regulated companies
Black Duck	Specialist in deep checks of C/C++ and embedded software
Snyk	Built for developers, with fast feedback in their daily tools
SonarQube	Started with code quality, then added security checks
GitHub Code Security	Built into GitHub, so easiest if we already use it
Semgrep	Lightweight and fast, with easy-to-write custom rules

Isn't a free tool good enough?

Free options exist, such as the open-source version of Semgrep and GitHub's free scanning for public projects. They are a reasonable start, but they usually cover fewer jobs and give leadership less reporting. Our 30-day test can run one rival next to Checkmarx One to check.

Is Checkmarx One the best tool for everyone?

No. GitHub Code Security may be simpler if all our code is on GitHub, and Semgrep is lighter for fast checks. No independent test compares them on the same code, so we propose our own.

Does it work with our programming languages?

Checkmarx says it supports 35 to 50+ languages and about 80 frameworks, and Forrester gave it full marks for language and framework support. Open question: which languages and frameworks does the team use most, so we can confirm each one in the trial?

Cost and contract

How much does it cost?

Checkmarx does not publish a price. It quotes by the number of developers, the modules chosen and the hosting model, and promises a quote within one business day. Third-party review sites cite roughly $1,000 to $3,000 per license per year before add-ons; treat that as a rough check only. Two rivals do publish prices: GitHub Code Security at $30 per active committer per month, and Semgrep Code at $30 per contributor per month, free up to 10 people.

What do the packages include?

Package	What is included
Essentials	Code scanning, open-source checks, API security, one risk dashboard
Professional (vendor's "most popular")	Everything in Essentials, plus tests of the running app, container security, fake-package protection, repository health
Enterprise	Everything in Professional, plus cloud setup file checks, leaked-password detection, secure-coding training
Add-ons	Fusion hybrid scanning, Triage and Remediation Assist, Developer Assist, AI Inventory

The vendor's page is inconsistent on whether cloud setup file checks sit in Professional, so get the contents of any package in writing. Source: Checkmarx pricing.

What are credits?

A prepaid balance used by Fusion, Triage Assist and Remediation Assist. When it reaches zero those actions pause until more is bought, with no automatic overage charges. That makes cost predictable, but we must estimate usage up front.

What should we ask for in the quote?

A three-year price for the same scope from every vendor: modules, number of developers, project limits, support level, hosting, credits for AI features and security terms.

Security and the 2026 attack

What happened?

In March 2026 attackers got into Checkmarx's GitHub repositories through an earlier attack on the Trivy tool. They used that access to publish tampered versions of Checkmarx add-ons: VS Code extensions, GitHub Actions and, on April 22, Docker images of its free KICS scanner. A modified Jenkins plugin followed on May 9, and stolen internal files were posted online in late April. See Checkmarx's incident page and Sophos's analysis.

Was Checkmarx's cloud service hacked?

Checkmarx says no. Working with Mandiant, it found that its AWS production environment was not affected and the Checkmarx One cloud platform was not compromised. Its page, last updated July 6, 2026, also said it was still working out whether any customer data was affected and would tell customers individually.

Should we still use it?

That is a judgement call for the team. A fast response and public disclosure count in Checkmarx's favor, but the tampered items were the same kinds of add-ons we would install. We recommend making written closure evidence a condition of onboarding, and hardening our own pipelines whichever tool we pick.

What do we ask Checkmarx for?

- The final report on what happened and a summary of the Mandiant findings
- Written confirmation of whether any of our data could be affected
- How they now prove that their downloads are genuine
- Up-to-date security audit reports, such as SOC 2 and ISO 27001
- A contract promise to tell us quickly if it happens again

What can we do on our side?

- Lock tools to exact approved versions instead of "latest"
- Turn off automatic updates for coding add-ons
- Limit what our build servers can reach on the internet
- Use short-lived credentials for scanning jobs
- Keep scanners away from production secrets

Day to day

Will it slow developers down?

It might, if scans are slow or noisy. User reviews on PeerSpot and AWS Marketplace disagree: one reports scans of 10 to 15 minutes, another says it is too slow to run on every code change. That is why the trial measures scan time on our own code and starts in warnings-only mode.

What is a false alarm, and how many will we see?

A false alarm is a warning about something that is not a real problem. Every tool raises some: a 2026 research paper that tested CodeQL, Semgrep and SonarQube found all three raised many. No independent figure exists for Checkmarx One, so the trial counts real findings against false alarms on our own code.

What tools does it plug into?

Coding tools: VS Code, JetBrains, Cursor, Windsurf and Kiro, through its Developer Assist helper (SD Times). Build pipelines: GitHub Actions and Jenkins. Still to confirm: GitLab, Azure DevOps and Bitbucket.

Does it check code written by AI assistants?

Yes, according to Checkmarx: Developer Assist runs inside AI-native editors and scans AI-written code as well as human-written code. Its claims about how much effort this saves are the company's own and untested.

Can it find every security problem?

No tool can. Reading code alone can miss some access-control and configuration problems, which is why it sits alongside tests of the running app, scans for leaked passwords and the rest of our security checks.

Rollout

What is the 30-day test?

1. Week 1, choose: pick 6 to 10 real projects and plant known flaws.
2. Week 2, scan: run Checkmarx One and one rival on the same code, and time every scan.
3. Week 3, judge: our security reviewers check each finding to see whether it is real.
4. Week 4, decide: work out the three-year cost, finish the security checks and vote go or no-go.

The pass mark is set before scanning starts: the share of findings that are real, the share of planted flaws found, scan time and cost. Open question: what values should the team set for each?

What happens after the test?

If it passes, a 90-day rollout follows. Days 0 to 30: finish the test and sign the contract. Days 31 to 60: pilot with two or three teams in warnings-only mode. Days 61 to 90: block releases with critical problems and add the remaining projects.

Who owns it?

Open question: the deck proposes owners for the test, the contract and the pipeline hardening, but none are named yet.

What if it fails the test?

We run the same test and pass mark on the next candidate, for example Veracode, Snyk or GitHub Code Security, so the comparison stays fair.

Plain-English glossary

Term	What it means
SAST	Scans our own code for security mistakes without running it, like a spell-checker
SCA	Checks the open-source parts we borrow for known weaknesses
DAST	Tests the running app the way an attacker would
IaC	Cloud setup written as files; mistakes here can expose data
Secrets	Passwords and keys accidentally left in code
ASPM	One dashboard that ranks risks from every scanner
False alarm	A warning about something that is not a real problem
Pipeline (CI/CD)	The automated line that builds, tests and releases our software
Supply-chain attack	Tampering with a trusted tool to reach the people who use it
Proof of concept	A short test on our own code before we commit
Open source	Software whose code is public and free to reuse
Cloud service (SaaS)	Software run and updated by the vendor over the internet
Air-gapped	Running with no connection to the internet at all

Sources

- Checkmarx pricing and packaging
- Checkmarx incident updates, July 6, 2026
- Sophos X-Ops: Checkmarx supply-chain attack
- Checkmarx page on the Forrester SAST Wave, Q3 2025
- SecurityBrief: Forrester SAST Wave coverage
- Business Wire: Gartner Magic Quadrant release, October 2025
- CodeQL supported languages and Semgrep supported languages

Figures from Verizon, IBM, Cyentia, the GitHub changelog, Semgrep's pricing page and the arXiv paper come from search summaries of those pages, not the full documents. Confirm them before quoting outside the team.